RESUMEN DE AUDITORÍA

Hallazgos de la auditoría al proyecto Integrate

Para: dueños del producto Integrate (Victor Manuel Ramirez Collantes y Sebastián Amaya)
De: equipo auditor TejiendoHogar
Fecha: 06/11/2026 · Versión evaluada: Versión 02 (aplicación migrada a nuevo framework) · Demo revisada: https://integrate-demo.pages.dev

1. Propósito

Este documento resume todas las incidencias que encontramos durante la auditoría cruzada de Integrate. Para cada una indicamos qué encontramos, en qué parte de la documentación entregada no se refleja o no se cumple, por qué creemos que ocurre esa diferencia y qué recomendamos. Las incidencias están ordenadas por nivel de prioridad para facilitar su atención.

Las fuentes revisadas fueron la Definición del Proyecto (0.0), el Plan de Gestión de la Calidad v1.10 (PGCP), el Software Architecture Description – C4 Model, el documento Diseño, Reutilización y Pruebas del Software v1.00, el repositorio del proyecto y la demo publicada (navegada el 04/11/2026 en vista móvil y de escritorio, con revisión automática de accesibilidad con axe-core, cabeceras HTTP, endpoints y tiempos de respuesta).

2. Resultado general

Integrate muestra un nivel técnico alto, superior a lo esperado en el curso, especialmente en arquitectura, modelo de datos, seguridad de autenticación, accesibilidad y gestión de calidad basada en evidencia. Las incidencias se concentran en tres frentes: **la protección de datos de las víctimas**, **la continuidad operativa del despliegue** y **la coherencia entre los documentos formales y el sistema construido**. Nuestro concepto preliminar es **Aprobado con observaciones**.

Sección evaluada	Puntaje	Cumplimiento
Secciones 6.1 a 6.7, 6.9 y 6.11 (primera revisión)	340 / 425	80,0 %
6.8 Interfaz y usabilidad	33 / 40	82,5 %
6.10 Despliegue, operación y mantenimiento	23 / 40	57,5 %

3. Niveles de prioridad

Prioridad	Criterio	Incidencias
Crítica	Riesgo legal o de daño a las personas (datos de víctimas) o de pérdida de información. Atender de inmediato.	3
Alta	Afecta el funcionamiento verificable, la seguridad o la fidelidad de un entregable principal. Atender antes de la entrega final.	6
Media	Afecta la medición de la calidad, la trazabilidad o la operación. Planear su corrección en el siguiente ciclo.	7
Baja	Errores de edición, de forma o de orden. Corregir en la revisión editorial.	4
Total		**20**

4. Resumen de incidencias

ID	Prioridad	Incidencia
H-01	Crítica	Datos sensibles de las víctimas sin la protección prometida
H-02	Crítica	Consentimiento de Habeas Data incompleto y política inaccesible
H-03	Crítica	Sin respaldo ni plan de recuperación de la base de datos
H-04	Alta	El Modelo C4 contiene contenido de otro proyecto
H-05	Alta	La infraestructura documentada no es la desplegada
H-06	Alta	Integración continua y pull requests declarados pero inexistentes
H-07	Alta	Código fuente expuesto y cabeceras de seguridad ausentes en el frontend
H-08	Alta	La demo no permite recorrer el Proceso 2 de punta a punta
H-09	Alta	Funciones documentadas sin interfaz o con fallas visibles
H-10	Media	Sin monitoreo ni registro verificable de incidentes
H-11	Media	Definición del Proyecto incompleta
H-12	Media	Evidencias de calidad desactualizadas frente al sistema
H-13	Media	Pruebas de aceptación sin cierre
H-14	Media	Consentimiento poco legible y voucher sin datos de emergencia
H-15	Media	Dependencia de una sola persona en el desarrollo
H-16	Media	Latencia en producción muy superior a la medida en local
H-17	Baja	Errores de edición en el Plan de Gestión de la Calidad
H-18	Baja	Sección 9 del documento de Diseño sin diligenciar
H-19	Baja	Textos de plantilla y detalles de interfaz
H-20	Baja	Elementos del repositorio no declarados o sin respaldo

5. Detalle de las incidencias

Cada ficha indica qué encontramos, dónde no se relaciona con la documentación entregada, por qué ocurre la diferencia y qué recomendamos.

Prioridad Crítica

H-01 · Datos sensibles de las víctimas sin la protección prometida	
Qué encontramos	El documento y el teléfono de los usuarios (tabla auth.users) se guardan sin cifrar (0 % cifrado). El detalle público de la experiencia muestra las coordenadas exactas del punto de encuentro (4.53257, -75.67304, verificado en la demo el 04/11/2026).
Dónde no se relaciona	PGCP, RNF-01 (100 % de datos sensibles cifrados y coordenadas con un máximo de 2 decimales); C4, ADR-09; ADR-0007 del repositorio.
Por qué no se relaciona	Los documentos prometen cifrado AES-256-GCM y ubicación ofuscada para todos los datos sensibles, pero el cifrado solo se aplicó a los datos que revelan la condición de víctima, y el endpoint público entrega la ubicación sin redondear. El propio PGCP §5.3 lo reporta como no conformidad, sin commit de corrección.
Recomendación	Cifrar documento y celular con AES-256-GCM e índice ciego (HMAC); redondear las coordenadas públicas a 2 decimales y entregar el punto exacto solo con la reserva confirmada; volver a medir el RNF-01.

H-02 · Consentimiento de Habeas Data incompleto y política inaccesible	
Qué encontramos	Solo el 66,67 % de los canales de alta registra el consentimiento (el administrador inicial no lo registra). En el registro, el enlace «Leer la Política de tratamiento de datos» apunta a https://integrate.invalid/..., un dominio que no existe, por lo que el usuario autoriza sin poder leer la política.
Dónde no se relaciona	PGCP, RNF-06 (100 %, cero tolerancia legal); C4, ADR-09 («registrando versión de la política»); Definición, marco legal (Ley 1581 de 2012).
Por qué no se relaciona	La documentación da por hecho un consentimiento informado en todos los canales y una política consultable. En el sistema la política es un borrador «sin validez legal» alojado en un dominio de ejemplo y la cuenta creada por bootstrap no pasa por el flujo de consentimiento.
Recomendación	Publicar la política en una URL real del dominio; registrar el consentimiento del administrador inicial; repetir la medición del RNF-06.

H-03 · Sin respaldo ni plan de recuperación de la base de datos	
Qué encontramos	No existe una política de respaldo automático ni una prueba de restauración. ADR-0027 reconoce que los respaldos del servidor se hacen «a mano». El despliegue es de nodo único, sin alta disponibilidad ni RTO/RPO definidos.
Dónde no se relaciona	C4, ADR-07 (almacenamiento en S3 que «mejora el tiempo de respaldo»); ADR-0035 (volumen cifrado en RDS con KMS); PGCP, característica de Fiabilidad.
Por qué no se relaciona	Los documentos formales describen una infraestructura administrada en AWS (RDS, S3, KMS) que incluye respaldos. El despliegue real se cambió a un VPS (Hetzner) detrás de Caddy, y ese cambio no trajo consigo un procedimiento de respaldo equivalente.
Recomendación	Programar pg_dump automático fuera del servidor, documentar el procedimiento, definir RTO/RPO y probar una restauración al menos una vez.

Prioridad Alta

H-04 · El Modelo C4 contiene contenido de otro proyecto	
Qué encontramos	El nivel 4 del C4 describe una app Android en Java con controladores de restaurantes y pedidos; varias páginas llevan el encabezado «FoodExpress UQ»; la sección 4 «Stack tecnológico» tiene solo la introducción, sin contenido. El C4 describe capas controller/service/repository, mientras el código es un monolito modular hexagonal.
Dónde no se relaciona	Software Architecture Description – C4 Model v1.0, nivel 4, encabezados de las secciones 3 y 4, sección 4.
Por qué no se relaciona	El documento se armó a partir de un entregable de otro proyecto y no se actualizó con la arquitectura real (backend-api, frontend-pwa, módulos hexagonales verificados con ArchUnit).
Recomendación	Reemplazar el nivel 4 con la estructura real del repositorio, completar el stack por capa y retirar los encabezados ajenos.

H-05 · La infraestructura documentada no es la desplegada	
Qué encontramos	La demo corre en Cloudflare Pages y la API detrás de Caddy en un VPS (cabeceras «server: cloudflare» y «via: 1.1 Caddy», verificadas el 04/11/2026). La API usa además un dominio temporal (sslip.io).
Dónde no se relaciona	Definición del Proyecto y C4 (despliegue en AWS; ADR-07 Amazon S3); ADR-0035 (RDS con KMS). El C4 no incluye diagrama de despliegue.
Por qué no se relaciona	Las decisiones ADR-0024 a ADR-0027 cambiaron la plataforma, pero esos cambios solo se registraron en el repositorio y no se propagaron a los entregables formales.
Recomendación	Agregar un diagrama de despliegue al C4 con la infraestructura vigente y actualizar la Definición y el ADR-0035.

H-06 · Integración continua y pull requests declarados pero inexistentes	
Qué encontramos	El repositorio no tiene carpeta .github/workflows; su único merge («promover la rama pruebas a main») se hizo sin pull request; los 69 commits son de un solo usuario.
Dónde no se relaciona	Diseño, Reutilización y Pruebas §3 («Pull Requests sobre ramas protegidas»), §4.2, §4.3, §6.1 y §8.6 (pruebas «en el pipeline de CI/CD»), §7.1 (revisión por pares) y §8.5; protocolo GIT-WF-001.
Por qué no se relaciona	La documentación describe el proceso objetivo, no el practicado. Las pruebas se ejecutan de forma local y el despliegue es manual.
Recomendación	Crear workflows de GitHub Actions (compilación, pruebas, cobertura, Gitleaks), proteger main y exigir revisión de otro integrante.

H-07 · Código fuente expuesto y cabeceras de seguridad ausentes en el frontend	
Qué encontramos	Los source maps están publicados (por ejemplo, /assets/index-fbUJk4tc.js.map responde 200 con el código fuente). Las páginas del frontend no envían Content-Security-Policy, Strict-Transport-Security ni X-Frame-Options (la API sí envía X-Frame-Options: DENY).
Dónde no se relaciona	Auditoría propia del equipo (docs/quality/auditoria-procesos-1-y-2-2026-10-27.md), que los clasifica como hallazgos altos; política SEC-DIR-004.
Por qué no se relaciona	Los hallazgos se identificaron el 27/10/2026 pero no tienen marca de resolución; la configuración de Cloudflare Pages (archivo _headers y opción de build sin source maps) no se ajustó.
Recomendación	Desactivar los source maps en producción y declarar las cabeceras de seguridad en _headers; cerrar los 7 hallazgos altos de la auditoría propia.

H-08 · La demo no permite recorrer el Proceso 2 de punta a punta	
Qué encontramos	La única experiencia publicada muestra «Por ahora no hay franjas abiertas en los próximos 60 días», por lo que no se puede reservar ni pagar. Las cuentas de prueba entregadas (tester1@integratedemo.test, tester.anfitrion@integratedemo.test) no permiten ingresar.
Dónde no se relaciona	Manual de usuario §3.3 y §3.4 (flujo de reserva y pago); guion de aceptación por rol; alcance de la auditoría (Proceso 2).
Por qué no se relaciona	Los datos de prueba de la semilla (dev_test_data.sql) solo existen en el entorno local. El propio manual llama a la demo «entorno local de desarrollo». El ambiente público no se pobló con franjas ni con cuentas que funcionen.
Recomendación	Cargar franjas abiertas y cuentas de prueba válidas por rol en la demo, y documentar cómo se reinician los datos.

H-09 · Funciones documentadas sin interfaz o con fallas visibles	
Qué encontramos	No hay pantallas para el Administrador ni para el Anfitrión (solo funcionan por API); no hay botón para cancelar reservas; «Mi cuenta» no permite editar nombre, teléfono ni contraseña; las reservas pagadas no aparecen en «Mis experiencias» hasta recargar la página.
Dónde no se relaciona	Definición del Proyecto §3 y §4 (actores y procesos); especificación técnica RF-01 a RF-20; RNF-22 (cancelación de 72 horas).
Por qué no se relaciona	Los requisitos se implementaron en el backend, pero la PWA no los expone. El manual (§2) lo reconoce, mientras que los documentos formales los presentan como funcionalidades del sistema.
Recomendación	Priorizar el botón de cancelación y la edición de perfil, invalidar la caché de reservas tras el pago, y declarar en la Definición qué funciones quedan solo por API.

Prioridad Media

H-10 · Sin monitoreo ni registro verificable de incidentes	
Qué encontramos	No hay endpoint de salud público (/api/actuator/health responde 401) ni monitoreo de disponibilidad o alertas. Los logs no salen en JSON estructurado. Jira no es accesible y no hay un registro de defectos con estado y fechas.
Dónde no se relaciona	PGCP §3.3 (MTTR desde Jira), RNF-29 (logs JSON con correlation ID, MTTD menor de 30 min); Diseño §4.2 y §4.3 (defectos en Jira).
Por qué no se relaciona	Existe el traceId (TraceIdFilter, cabecera x-trace-id) pero no la salida estructurada ni las herramientas de seguimiento que el plan usa como fuente de datos. Por eso el MTTR y el MTTD no se pueden medir.
Recomendación	Exponer un health check sin autenticación, configurar un monitor de disponibilidad, emitir logs JSON y llevar un registro de incidentes accesible.

H-11 · Definición del Proyecto incompleta	
Qué encontramos	El cronograma está vacío («<Introduzca contenido y borre cuadro>»); el encabezado conserva «<Nombre del proyecto>»; la tabla de contenido tiene «<Nombre del proceso>»; hay filas duplicadas; se mencionan diagramas BPMN «modelados en Bizagi/Camunda» que no se incluyen; el campo «Aprobado por» está vacío.
Dónde no se relaciona	0.0 Integrate – Definición del Proyecto, encabezado, tabla de contenido, §4 y §5.
Por qué no se relaciona	La planeación real (roadmap con Gantt, matriz de riesgos) vive en el repositorio y no se trasladó al entregable.
Recomendación	Completar el cronograma con las fases del roadmap, adjuntar los BPMN y hacer una revisión editorial.

H-12 · Evidencias de calidad desactualizadas frente al sistema	
Qué encontramos	El informe evidencias-metricas está fechado el 11/10; el PGCP §5.2 y §5.5 siguen marcando como «Pendiente Fase 2» los RNF del Proceso 3 (RNF-14, 17, 18, 19, 20 y 22), aunque el Proceso 3 ya está en el repositorio; la matriz de trazabilidad los marca «Cumple» sin evidencia regenerada; PROJECT_STATUS dice «Última actualización: 2026-10-07».
Dónde no se relaciona	PGCP §5; Diseño §4.3 (última ejecución de referencia 11/10/2026 sobre la rama feature/fase-1-mvp-transaccional); matriz de trazabilidad.
Por qué no se relaciona	El Proceso 3 se integró con 16 commits en 3 días y la suite de calidad no se volvió a ejecutar para regenerar la evidencia.
Recomendación	Ejecutar la suite completa sobre el commit final y regenerar el informe, la sección 5 del PGCP y PROJECT_STATUS.

H-13 · Pruebas de aceptación sin cierre	
Qué encontramos	El guion del 30/10 registró 27 pasos fallidos y 9 errores (E-01 a E-09); el rol Gestor de Enlace quedó «No aprobado»; la ejecución fue automatizada con Chrome emulado, sin usuarios ni teléfono real (G-43 cámara y G-54 instalación pendientes); el RNF-12 (enrolamiento en menos de 3 min) no se ha medido; no hay acta de validación final.
Dónde no se relaciona	Diseño §6.1 y §7.1 (aceptación por el Gestor y las Asociaciones; pruebas de usabilidad en campo).
Por qué no se relaciona	El plan prevé pruebas con usuarios reales en su entorno, pero solo se ejecutó la versión automatizada.
Recomendación	Repetir el guion con usuarias reales y un teléfono físico, cerrar E-01 a E-09 y firmar un acta de validación.

H-14 · Consentimiento poco legible y voucher sin datos de emergencia	
Qué encontramos	La legibilidad Flesch-Szigriszt del consentimiento es de 56 puntos (41,5 en el texto de condición de víctima). El voucher PDF no incluye EPS ni contacto de emergencia. En el registro, la autorización de salud dice «(opcional)» y en la misma línea «Es necesario para reservar».
Dónde no se relaciona	PGCP RNF-15 (más de 60 puntos) y RNF-23 (100 % de vouchers con EPS y contacto); NC-07.
Por qué no se relaciona	El RNF-23 choca con la minimización de datos de salud de ADR-0010 y no se ha decidido cuál prevalece; los textos legales no se simplificaron.
Recomendación	Simplificar los textos; decidir entre incluir EPS y contacto en el PDF o ajustar el RNF-23; unificar el mensaje opcional/obligatorio.

H-15 · Dependencia de una sola persona en el desarrollo	
Qué encontramos	Los 69 commits pertenecen a un solo usuario; no hay matriz de roles (RACI) con nombres ni actas de seguimiento.
Dónde no se relaciona	Diseño §8.5 (Sebastián Amaya y Víctor Manuel Ramírez como autores conjuntos, con revisión cruzada por pull request).
Por qué no se relaciona	La distribución del trabajo y la revisión entre pares que describe el documento no se evidencian en el repositorio.
Recomendación	Repartir tareas, revisar cambios entre integrantes y dejar evidencia (commits, pull requests, actas).

H-16 · Latencia en producción muy superior a la medida en local	
Qué encontramos	En la demo, 15 consultas seguidas al catálogo respondieron todas con 200, pero entre 1,08 y 1,25 s. La carga inicial muestra «Cargando…» varios segundos.
Dónde no se relaciona	PGCP §5.2 (RNF-10: p95 de 148,6 ms con 500 usuarios, medido en entorno local; criterio menor de 1.500 ms).
Por qué no se relaciona	Las mediciones del plan se hicieron en un entorno local aislado y no en el despliegue real. El criterio se cumple, pero con poco margen y sin carga concurrente.
Recomendación	Repetir las pruebas k6 contra el despliegue real y registrar los resultados como evidencia.

Prioridad Baja

H-17 · Errores de edición en el Plan de Gestión de la Calidad	
Qué encontramos	RNF-02 duplicado (4.1.2 y 4.2.1), RNF sin número (4.1.5 y 4.5.2) y «RNF: 030»; métricas de §3.3 con fuentes de datos copiadas de otra fila (el MTTR usa «entregas de componentes realizadas vs. planificadas»); instrucciones de plantilla sin borrar; portada en v1.00 con cambios hasta v1.10.
Dónde no se relaciona	1.1 Plan de Gestión de la Calidad v1.10, §3.3 y §4.
Por qué no se relaciona	Revisión editorial incompleta. El propio PGCP §5.4 reconoce el problema de numeración.
Recomendación	Unificar la numeración, corregir las fuentes de las métricas y actualizar la portada.

H-18 · Sección 9 del documento de Diseño sin diligenciar	
Qué encontramos	La §9.1 conserva «<Introduzca contenido y borre cuadro>» y una tabla con justificaciones de otro sistema («generación de reportes», «gestión de clientes y productos»); la §9.2 conserva los ejemplos de la plantilla («Ej. Usabilidad», PN01).
Dónde no se relaciona	2 Integrate – Diseño, Reutilización y Pruebas del Software v1.00, §9.
Por qué no se relaciona	Las pruebas no funcionales sí están diseñadas en el PGCP, pero no se trasladaron a esta sección.
Recomendación	Diligenciar la §9 con los atributos y pruebas reales (k6, axe-core, seguridad) o remitir explícitamente al PGCP.

H-19 · Textos de plantilla y detalles de interfaz	
Qué encontramos	El detalle público dice «Experiencia de ejemplo: puede editarla desde su cuenta». El manual llama a la URL pública «entorno local de desarrollo». En la pantalla de ingreso, el enlace «Manual de usuario» del pie queda tapado por la barra inferior.
Dónde no se relaciona	Manual de usuario §1; interfaz de la demo (verificado el 04/11/2026).
Por qué no se relaciona	Los textos de la semilla de desarrollo y del manual no se ajustaron al publicar la demo.
Recomendación	Reemplazar los textos de ejemplo, corregir el manual y añadir margen inferior al pie.

H-20 · Elementos del repositorio no declarados o sin respaldo	
Qué encontramos	El modelo relacional menciona políticas RLS que no aparecen en las migraciones; se versionan 108 MB de archivos generados (graphify-out) y la carpeta .claude sin declarar el uso de herramientas de IA; no hay archivo de licencia. Las decisiones vigentes (Argon2id en vez de BCrypt, JaCoCo en vez de SonarQube, contraste 7:1) se registraron en el PGCP §5.4 sin actualizar el texto del plan.
Dónde no se relaciona	docs/modelo_relacional.md; PGCP §4 (RNF-03, RNF-04, RNF-28) y §5.4; entregables formales.
Por qué no se relaciona	Los documentos fuente no se actualizaron después de los cambios y las herramientas usadas no se declararon.
Recomendación	Retirar o implementar las RLS, limpiar archivos generados, declarar el uso de IA, agregar una licencia y actualizar el texto de los RNF.

6. Fortalezas a conservar

- Arquitectura monolítica modular hexagonal documentada en ADR y verificada automáticamente con ArchUnit.
- Modelo de datos en 3FN (47 tablas en 9 esquemas, 94 llaves foráneas, 205 restricciones CHECK) con migraciones Flyway.
- Autenticación sólida: JWT RS256 con refresh rotativo, Argon2id y RBAC con 100 % de efectividad medida.
- Control de concurrencia verificado: 0 % de sobreventa.

- Interfaz accesible y consistente: 0 violaciones de WCAG 2.1 A/AA con axe-core en inicio, detalle y registro; validaciones en línea claras; página 404 propia; buena adaptación a escritorio.
- Transparencia: el propio equipo reporta sus no conformidades y pendientes en el PGCP.

7. Próximos pasos sugeridos

- **Inmediato:** cerrar H-01, H-02 y H-03 (protección de datos, consentimiento y respaldos) y volver a medir los RNF-01 y RNF-06.
- **Antes de la entrega final:** actualizar el C4 y la Definición (H-04, H-05, H-11), activar CI y pull requests (H-06), corregir la configuración de seguridad del frontend (H-07) y poblar la demo con franjas y cuentas válidas (H-08).
- **Siguiente ciclo:** regenerar la evidencia de calidad, cerrar las pruebas de aceptación con usuarios reales y habilitar monitoreo (H-10, H-12, H-13).
- Cuando se resuelvan los hallazgos, quedamos atentos para verificar las correcciones y actualizar el resultado de la auditoría.

Atentamente,
Equipo auditor TejiendoHogar
Ingeniería de Software III